DECRYPTING BLOCKCHAIN: THE ART OF THE STEAL

Brandon Barham (branbarh@umich.edu)
Brandon Geib (geibba@umich.edu)
Joshua Bisdorf (bisdorfj@umich.edu)
Vatsal Agarwal (vatsalag@umich.edu)

---

1. Abstract

This paper explores the foundational technologies behind blockchain and analyzes them in the context of security, privacy, and real-world use. Beginning with a breakdown of hash functions and elliptic curve cryptography, we examine how these cryptographic primitives underpin blockchain systems like Bitcoin. We then thoroughly outline how blockchains are formed and how transactions are carried out on the Bitcoin and Monero networks.

The latter half of the paper examines Monero and discusses the advantages and potential pitfalls of cryptocurrency's privacy-focused aspects. We evaluate how the anonymity provided by such systems can be undermined and abused, particularly through non-cryptographic vulnerabilities. These concerns are brought to life in a case study of the "Save the Kids" token scandal.

Ultimately, this paper argues that while cryptography can enforce strong mathematical guarantees, it cannot fully safeguard against the broader spectrum of human-driven exploitation.

2. Blockchain Fundamentals

Blockchain is a prime example of using cryptographic primitives to solve problems other than encryption. At a high level, blockchain implements cryptographic hash functions and elliptic curves to record a tamper-proof chain of events securely.

2.1. A Brief History of Blockchain

Blockchain was first conceptualized in 1991 by Stuart Haber and W. Scott Stornetta, who originally designed it for securely timestamping digital documents [1]. Over the next 20 years, researchers improved and formalized the initial blockchain concept (e.g., Hal Finney's 2004 paper on "Reusable Proof of Work," which was later adapted into the modern "proof-of-work" algorithm used by Bitcoin [2]), making blockchain more secure, efficient, and useful.

Although the blockchain had several practical applications, it went mostly unnoticed by the wider cryptographic community until 2008. In October of that year, Satoshi Nakamoto published his white paper titled “A Peer-to-Peer Electronic Cash System,” [3] which eventually led to the introduction of Bitcoin, the world’s first decentralized currency. Since then, blockchain has been implemented in over 25,000 cryptocurrencies [4] and is now used for supply chain verification, voting systems, and identity verification [5].

To fully understand the blockchain, it is important to understand the underlying cryptographic primitives—hash functions and elliptic curves—first. The following sections will outline these concepts.

2.2. An Overview of Hash Functions

A hash function (sometimes referred to as a hash function family), at a high level, is an efficient (i.e., runs in polynomial-time), deterministic function that maps inputs of some length, n, to outputs of some fixed length less than n.

For a hash function to be considered cryptographically secure, it must be resilient to collisions. We formally define collision resistance in the following section.

2.2.1. Collision-Resistance

Collision-resistance ensures that finding two distinct inputs that hash to the same output is difficult. More formally, a hash function is collision-resistant if the following advantage is negligible for any efficient adversary:

$$\mathrm{Adv}_H^{\mathrm{CR}}(\mathcal{A}) = \mathrm{Pr}_{k,(x,x')}\left[H_k(x) = H_k(x')\right]$$

…where $k \leftarrow \mathcal{K}$ at uniform random, assuming $\mathcal{K}$ is the key space, and $(x, x') \leftarrow \mathcal{A}_k(1^n)$, where $x \neq x'$.

2.2.2. Hash Functions in Practice

In practice, Bitcoin uses the double SHA-256 hash function (SHA-256 applied twice), a cryptographically secure hash function under collision-resistance [6]. Like most hash functions, SHA-256 doesn’t use a random key, but rather uses public “key-like” values to generate hashes (note that the key, k, is always available to our adversary in the above advantage formulas). The exact implementation details of SHA-256 are not important in the context of implementing blockchain, but Lane Wagner published a detailed description of how it works, if you’re interested [7].

Different cryptocurrencies often employ different hash functions depending on the requirements for the specific implementation. For example, the Monero cryptocurrency uses the Keccak-256 hash [8], which is also cryptographically secure under collision-resistance. So long as the hash function is collision-resistant, blockchain and (in the case of Bitcoin) proof-of-work (PoW) algorithms can be securely implemented.

The importance and application of hash functions will be explored in later sections, after introducing the foundations of elliptic curve cryptography.

2.3. An Introduction to Elliptic Curve Cryptography

Another prerequisite to understanding the implementation of blockchain is elliptic curve cryptography. At a high level, elliptic curve cryptography can be thought of as a more efficient substitution for RSA (or other schemes similar to RSA). The main benefit of elliptic curve cryptography is that much smaller key sizes can be used with the same security guarantees [9].

Elliptic curve cryptography is based on the properties of elliptic curves, which are curves that (generally) conform to the following formula:

$$y^2 = x^3 + ax + b$$

…where a and b are constants that define the exact type of curve. For example, Bitcoin uses the "secp256k1" curve, for which $a = 0$ and $b = 7$ [10], yielding:

$$y^2 = x^3 + 7$$

Figure 1, below, graphs this curve in two dimensions:

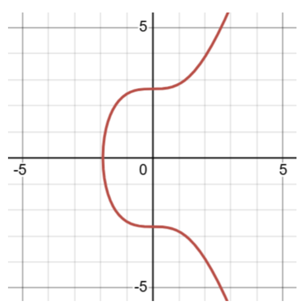

Figure 1. A graph of $y^2 = x^3 + 7$, the elliptic curve used by Bitcoin.

Elliptic curves have specific properties that make them useful for cryptography. One such property is that the points on an elliptic curve (along with a special point at infinity, denoted "∞") make up a finite abelian group closed under point addition and scalar multiplication [11], [12].

Below, we define point addition, scalar multiplication, and the additive identity and inverse.

2.3.1. Addition on an Elliptic Curve

To add two points on an elliptic curve together, we can't simply add the x and y coordinates, since this almost always results in a point that doesn't lie on the curve. As such, we need to "redefine addition" for our given application.

Assume we have two arbitrary points, $P = (P_x, P_y)$ and $Q = (Q_x, Q_y)$, which lie somewhere on the curve. Figure 2, below, depicts one possible pairing of P and Q.

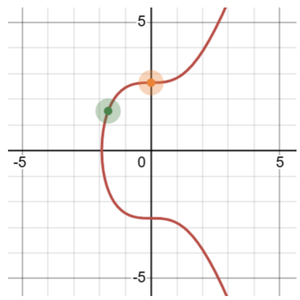

Figure 2. Sample points for P and Q, graphed.

To add P and Q together, we use the following procedure:

- **Find the Line:** We first determine the line that passes through P and Q. As in elementary algebra, we can calculate the slope of this line (denoted λ) as $\lambda = (P_y - Q_y)/(P_x - Q_x)$.
- **Find the Intersection:** This line will intersect with P, Q, and a third point on the curve (which we will call T). We can calculate the x and y coordinates of this third point as $T_x = \lambda^2 - (P_x + Q_x)$ and $T_y = \lambda(R_x - P_x) + P_y$.
- **Flip Over the X-Axis:** Finally, we flip T over the x-axis to get the result of $P + Q$ (which we will call R). The formulas for R_x and R_y are thus $R_x = \lambda^2 - (P_x + Q_x)$ and $R_y = \lambda(P_x - R_x) - P_y$.

Figure 3, below, depicts these three steps:

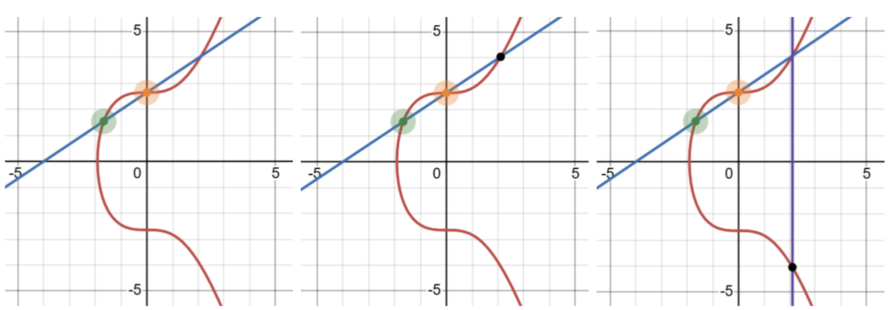

Figure 3. Visualizing the addition of P and Q in ECC.

With that, we're done! We've successfully added P and Q. However, there are a few details that might feel unsatisfying.

For example, why do we reflect the third point over the x-axis instead of using it directly? To explore this idea, imagine a new version of elliptic curve addition where we use the third point directly, letting $P+Q=T$. However, since P, Q, and T lie on the same line, it follows that $T+Q=P$ must also be true. If we substitute the first equation into the second, we get $P+Q+Q=P$. If we substitute the second equation into the first, we get $T+Q+Q=T$. This implies that $P=T$, which is generally not the case!

By reflecting T over the x-axis to get R, we avoid this issue entirely. More formally, this reflection ensures that the set of points on the elliptic curve (along with the point at ∞) form an abelian group [13].

Another concern that you may have is the issue of adding a point to itself. In this case, there are infinitely many choices for the slope of the line, since the points are directly on top of one another. The general convention is to use the tangent of the elliptic curve at that point, which we can calculate as follows:

$$\lambda = \left(\frac{3P_x^2}{2P_y^2}\right)^2$$

This concept should intuitively make some sense since if we brought two points closer and closer together until they overlapped, the slope of the line between them would approach the tangent of the elliptic curve. Figure 4, below, depicts an example of this.

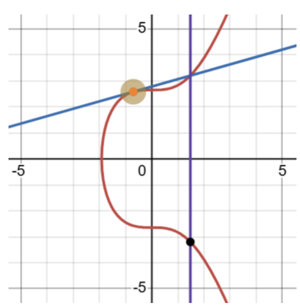

Figure 4. An example of point addition when $P=Q$.

The final concern you might have is the issue of non-existent third intersections (i.e., when the line between P and Q intersects only with P and Q). For example, consider when $P=(P_x,P_y)$ and $Q=(P_x,-P_y)$. This case is depicted by Figure 5, below.

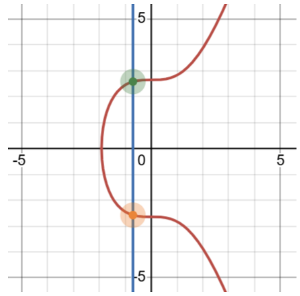

Figure 5. An example where the line between P and Q only intersects twice, with P and Q.

In this case, we say that the result of $P + Q$ is ∞ (i.e., "the point at infinity"). This special point is further discussed in the following sections [12].

2.3.2. Scalar Multiplication on an Elliptic Curve

Given a scalar, k, and a point on the curve, P, we can calculate kP (i.e., the scalar multiplication of k and P) simply by adding P to itself k times.

For example, to calculate $3P$, we can first calculate $P + P$ by following the steps for adding a point to itself, as covered in the previous section. From there, we can compute $2P + P$ directly.

It's worth noting that, in general, scalar multiplication is non-linear, which gives rise to finite cyclic groups (similar to cyclic groups in modular arithmetic). This phenomenon leads to the discrete logarithm problem for elliptic curves (further covered in a later section) [12].

2.3.3. The Additive Identity and Inverse

The "point at infinity," ∞, is significant for several reasons. It most notably acts as the additive identity when dealing with elliptic curves. In other words, for any point P on the curve, $\infty + P = P$.

To visualize this, imagine ∞ as a point that lies infinitely far up the curve, causing it to sit directly above every other point. When we calculate $\infty + P$, the line between ∞ and P intersects the curve at $(P_x, -P_y)$. When we reflect over the x-axis (the third step of point addition), we end up back at P. Figure 6, below, illustrates this. The green circle represents P, and the black circle represents the result of $\infty + P$.

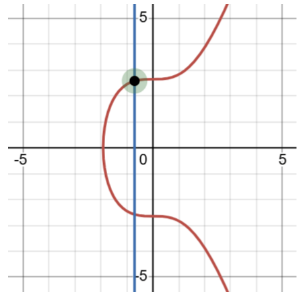

Figure 6. The addition of ∞ and P, visualized geometrically.

The point at infinity, ∞, also plays a key role when determining the additive inverse. Given a point on the curve, P, we define $-P$ (i.e., P's additive inverse) as the point that satisfies the following equality:

$$-P + P = \infty$$

Note that, for all $P = (P_x, P_y)$, its inverse can be computed as $-P = (P_x, -P_y)$ [12].

2.3.4. The Elliptic Curve Discrete Logarithm Problem (ECDLP)

As mentioned earlier, the points on an elliptic curve (along with a special point at infinity, denoted "∞") make up a finite abelian group closed under point addition and scalar multiplication. This group possesses the necessary structure to give rise to the discrete logarithm problem.

To understand the discrete logarithm problem in the context of elliptic curves, imagine you are given the following formula, where P and Q are points on the elliptic curve and k is a scalar:

$$P = kQ$$

It is straightforward to compute P given k and Q by performing scalar multiplication, as defined previously. We can use an approach similar to efficient modular exponentiation (i.e., by calculating the multiples of 2 times Q, and then adding the relevant multiples together) to calculate P in linear time.

However, it is computationally difficult (taking exponential time) to determine k given the points P and Q. This one-way computational difficulty is known as the "elliptic curve discrete logarithm problem" (ECDLP), and is analogous to the traditional discrete logarithm problem (DLP) [12].

This property of elliptic curves is essential for cryptographic applications and often forms the primary basis of their security. In the context of blockchain, elliptic curve cryptography is used to generate and verify digital signatures, which authenticate transactions recorded on blockchain ledgers (such as the Bitcoin network).

2.4. Putting the "Block" in Blockchain

On the Bitcoin network, every block shares the same set of fields. These fields can be grouped into four categories:

- **Block Size:** Stores the length of the block, in bytes (excluding the block size field itself).
- **Block Header:** Contains the block's metadata.
- **Transaction Count:** Stores the number of transactions in the "transactions" field.
- **Transactions:** The transactions themselves, stored alongside a Merkle tree summarizing the transactions; Merkle trees enable efficient search and verification over the transactions recorded within the current block [14].

As mentioned above, the block's header field contains metadata about the block, including the following sub-fields:

- **Version:** The version of the Bitcoin network during which the block was created.
- **Hash of the Previous Block:** The SHA-256 hash of the previous block in the blockchain.
- **Merkle Root:** The hash pointing to the root of the Merkle tree in the "transactions" field.
- **Timestamp:** The time of the block's creation, in UTC.
- **Difficulty Target:** The proof-of-work algorithm (covered in Section 2.5) difficulty target for this block.
- **Nonce:** A field with no meaning that is only used for the proof-of-work algorithm.

The Bitcoin network calculates the hash for a given block by passing the block header (and only the block header) through the double SHA-256 hashing algorithm. For example, the genesis block (further explained in Section 2.4.2) yields the following hash:

$$000000000019d6689c085ae165831e934ff763ae46a2a6c172b3f1b60a8ce26f$$

For a detailed outline of the contents of each block on the Bitcoin network, refer to Chapter 7 of O'Reilly's "Mastering Bitcoin" [15].

2.4.1. Chains and Forks

Since each block contains the hash of the previous block, the resulting structure is a chain of blocks (hence why it is termed a "blockchain"). Each block can only have one parent, but a single block can, temporarily, have multiple children.

If a block has multiple children, the resulting configuration is referred to as a "fork." A fork usually occurs when two Bitcoin miners mine a block at approximately the same time. The Bitcoin network uses a consensus mechanism to determine which block demonstrates the highest "proof-of-work" (covered further in Section 2.5). The lesser blocks are orphaned (and eventually discarded) from the network.

This mechanism ensures that every block has exactly one parent and one valid child, preventing the network from branching. This feature enhances the efficiency and security of the blockchain since there are fewer endpoints to handle, resulting in fewer points of failure.

2.4.2. The Genesis Block

Since each block has exactly one parent and one child (and cycles are not allowed in a blockchain), this implies the existence of an origin, "genesis," block. Indeed, the genesis block was mined in 2009 by Satoshi Nakamoto (the inventor of Bitcoin) and has a height (i.e., an index) of 0 on the Bitcoin network [16]. Interestingly, the reward for mining the genesis block is unredeemable, unlike any other mining reward on the Bitcoin network.

2.5. Bitcoin's Proof-of-Work Algorithm

Arguably, the most important part of the Bitcoin blockchain is its proof-of-work algorithm. This algorithm requires miners to prove that they have performed a certain level of computation before they are allowed to append a new block to the end of the blockchain. This mechanism prevents blocks from being added, removed, or altered at will and is core to the blockchain's security.

Recall that each block contains the hash of the previous block. For example, we might have three blocks, which are visualized in Figure 7 below:

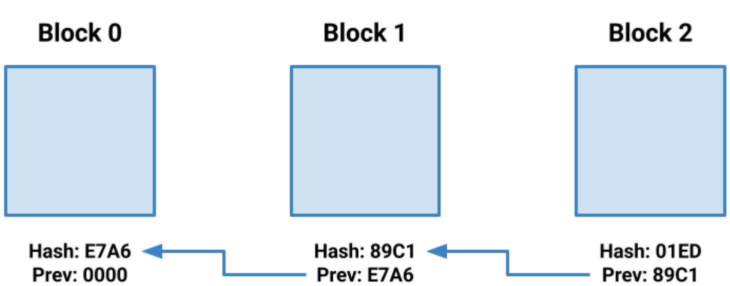

Figure 7. A simplified blockchain.

Notice that if we changed the data stored in block 1, then its hash would (with a non-negligible probability) also change. By the definition of collision resistance, it is computationally infeasible to change a block such that its hash remains unchanged. Therefore, the "previous hash" stored in block 2 would become invalid, since it no longer matches block 1's new hash.

To rectify this, one would have to update the "previous hash" field in block 2, and then recalculate block 2's hash. This process will continue down the chain, until all blocks have been corrected. However, modern computers are incredibly efficient, and can update hashes in a matter of nanoseconds. Thus, the proof-of-work algorithm is needed.

The proof-of-work algorithm requires that the hash of each block meets a certain set of requirements. On the Bitcoin network, this requirement is that the numerical value of each block's hash is less than the threshold determined by the network's current "difficulty target." This difficulty target is updated every two weeks as computation power on the network fluctuates [17].

For example, assume the difficulty target is set to $00\mathrm{FF}$ on our simplified blockchain. For a block to be added to the network, its hash must be less than or equal to this difficulty target. If a block hashed to 1234, it would not be valid, since $1234 \not\leq 00\mathrm{FF}$. However, if a block hashed to $00\mathrm{E}7$, it would be valid, since $00\mathrm{E}7 \leq 00\mathrm{FF}$.

The nonce field is used to change the hash of a block without altering the data stored within it. By trying different values in the nonce field, Bitcoin miners can modify the hash without affecting other information within a block. Eventually, once a miner finds a nonce that results in a valid hash, the block is added to the blockchain network. On Bitcoin's blockchain, the difficulty target is set such that mining a new block takes approximately 10 minutes.

With the proof-of-work algorithm in place, manipulating the blocks on the network becomes significantly harder since recomputing valid hashes now requires substantial computational effort. This computational requirement upholds the integrity of the blockchain [2].

2.6. Blockchain Distribution and Consensus

In addition to proof-of-work, the blockchain relies on its decentralized nature and a consensus mechanism for security. Whenever a new miner joins the network, it syncs with the other nodes on the network to construct copies of the current blockchain. If some of these copies disagree (i.e., the blocks don't perfectly match up), the longest valid blockchain with the most cumulative proof-of-work is selected as the "real" blockchain.

A similar process is employed whenever a new block is added to the blockchain. When a miner finds a valid hash for a new block, it broadcasts the completed block to every other node on the network. These other nodes then verify the block's data and hash and append it to their local copy of the blockchain. If two or more miners arrive at a solution at roughly the same time (creating a fork), the path with the highest cumulative proof-of-work is selected as the "real" path. The blocks in the other paths are orphaned from the network.

The decentralized nature of the blockchain is one of its greatest strengths, since to tamper with the network, one would need to gain access to over half the computation power on the network to bypass the consensus algorithm. If an adversary gained access to over half the computation power, they could create a longer (but fraudulent) chain with a higher cumulative proof-of-work, enabling the adversary to forge transactions. By splitting the network's computation power across hundreds of thousands of nodes, such an attack is practically impossible [18].

3. Transactions - From Transparency to Obfuscation

The previous section explained how blocks are chained and committed by proof-of-work. Day-to-day, however, users experience a cryptocurrency as *transactions* that move value. This section examines the cryptographic machinery behind those transfers, first in Bitcoin's transparent UTXO model and then in Monero's privacy-preserving construction.

3.1. Bitcoin Transaction Anatomy

A Bitcoin transaction is a state transition defined by:

$$\{\mathrm{UTXO}_i\}_{i<m} \xrightarrow{\mathrm{tx}} \{\mathrm{UTXO}'_j\}_{j<n}$$

…and is subject to the *conservation law*:

$$\sum_i v_i = \sum_j v'_j + f$$

…where the *fee* is:

$$f = \sum_i v_i - \sum_j v'_j \, .$$

The on-chain identifier is given as:

$$\mathrm{txid} = \mathrm{SHA256}^2\big(\mathrm{serialize(tx)}\big)$$

A raw transaction contains four fields [19]:

- **Version:** Format version (currently 1 or 2).
- **Inputs (*tx_in*):** Each references a previous UTXO and carries an unlocking script;
- **Outputs (*tx_out*):** Each defines a new UTXO and its locking script;
- **Locktime:** The earliest block height or UNIX time at which the transaction becomes valid.

In the *UTXO model*, every coin lives in exactly one output until it is referenced as an input; the global state is the set of all unspent outputs.

3.1.1. Locking and Unlocking Scripts

The canonical locking script is called *Pay-to-Public-Key-Hash* (P2PKH), and uses the following opcodes [20]:

```
OP_DUP OP_HASH160 <20-byte-hash> OP_EQUALVERIFY OP_CHECKSIG
```

To spend the output, the redeemer supplies a *scriptSig*, defined as:

```
<sig> <pubKey>
```

Bitcoin Script concatenates the unlocking script (from the input) and the locking script (from the UTXO being spent), then executes the resulting script stack in left-to-right order. If the final stack element is *true*, the input is authorized.

3.1.2. ECDSA Signatures on *secp256k1*

Let G be the base point of the elliptic-curve group *secp256k1* (the elliptic curve for Bitcoin, as discussed in Section 2.3) of order n. A user's key-pair is $(d, Q = dG)$. To sign the double-SHA-256 hash z of the serialized transaction (with *scriptSig* blanked):

1. **Choose** random $k \in 1, \ldots, n-1$.
2. **Compute** $R = kG$ and $r \equiv x_R \bmod n$.
3. **Compute** $s \equiv k^{-1}(z + dr) \bmod n$.
4. **Output** signature (r, s).

The signature proves that the sender controls the private key corresponding to the recipient address, ensuring authenticity without revealing the key itself. The verification process confirms that the following (in)equalities hold:

$$0 < r, s < n$$
$$s^{-1}zG + s^{-1}rQ = R$$

The modular inverses k^{-1} and s^{-1} emphasised in Section 6 of "The Mathematics behind Blockchain" [11] ensure only the holder of d can create (r, s), yet anyone can verify it.

3.1.3. From Mempool to Finality

After signing, the transaction is broadcast to the *mempool*. A node relays it if (i) all inputs are unspent and (ii) the fee rate f/vsize clears its minimum. Miners collect high-fee transactions, assemble them into a candidate block, and iterate the nonce until the block hash satisfies the difficulty target. The transaction is considered final once the block is confirmed six times (which takes approximately 60 minutes)

3.2. Privacy Limits of the Bitcoin Model

Because every UTXO, address, and signature is permanently recorded, third-party observers can perform *address clustering*, *taint analysis*, and *graph heuristics* to deanonymize users. Section 5 details real-world exploits of this transparency.

3.3. Monero Transaction Anatomy

Monero pursues the opposite goal: conceal the sender, receiver, and amount while preserving verifiability. It achieves this by layering three cryptographic shields.

3.3.1. Stealth Addresses

A recipient advertises long-term public keys (A_p, B_p). For each payment, the sender chooses random $r \leftarrow_R 1, \ldots, l-1$ and computes a *one-time destination*, given as:

$$P = H_s(rA_p)G + B_p$$

...where H_s is hashed using Keccak-256 to scalar mod l. Only the recipient, who knows the *view key* a such that $A_p = aG$, can recognize the outputs addressed to P.

3.3.2. Ring Signatures (MLSAG)

To spend an output P the wallet forms a ring $P_0, \ldots, P_{N-1}$ with P at a secret index π and produces an *MLSAG* signature proving knowledge of the private key x corresponding to one ring member. A *key-image*, given as:

$$I = x, H_p(P)$$

...(where H_p hashes to an elliptic-curve point) links multiple attempts to spend the same output without exposing π [23].

3.3.3. Ring Confidential Transactions

Amounts are concealed with *Pedersen commitments* [21], given as:

$$C = vG + bH$$

...where v is the amount and b is a blinding factor. A Bulletproof range proof shows that:

$$0 \leq v < 2^{64}$$

…without revealing v. The MLSAG further proves the *balance equation*, given as:

$$\sum C_{\text{in}} - \sum C_{\text{out}} = fH$$

…where f is the network fee [22].

3.3.4. Verification and Decoys

Full nodes verify (i) I is unique, (ii) the MLSAG equations hold, and (iii) the commitment balance equals the fee commitment. Decoys are sampled from an age-biased distribution to resist temporal analysis, although early transactions (ring size ≤ 3) remain partially traceable.

3.4. Bitcoin vs Monero — Key Differences

There are a few key differences between Bitcoin and Monero:

- **Address Generation:** Static P2PKH/P2WPKH in Bitcoin; one-time stealth addresses in Monero.
- **Sender Privacy:** None in Bitcoin (input addresses revealed); ambiguous in Monero via ring signatures.
- **Amount Visibility:** Plaintext in Bitcoin; hidden in Monero through commitments and Bulletproofs.
- **Signature Scheme:** ECDSA over *secp256k1* (Bitcoin) versus MLSAG over *ed25519* (Monero).
- **Chain-Analysis Effectiveness:** High for Bitcoin (≥ 95 % cluster accuracy in recent studies); low and probabilistic for Monero.

3.5. Security Implications

Transparency aids auditing and fork choice but enables surveillance and selective censorship. *Privacy*, by default, protects individuals yet increases transaction size and complicates regulatory compliance. Therefore, the same primitives—elliptic curves, hash functions, zero-knowledge proofs—can be composed to achieve diametrically opposed privacy guarantees. Choosing between Bitcoin and Monero is ultimately a question of acceptable trade-offs for a given use case.

4. Monero, and How to Break It

Monero, launched in 2014, is a privacy-centric cryptocurrency prioritizing anonymity, fungibility, and untraceability. Its underlying technology sets it apart from transparent blockchains like

Bitcoin, making it a preferred medium of exchange for those seeking financial privacy—and increasingly, cybercriminals. This section explores Monero's core privacy features and reviews current methods and efforts to undermine its anonymity.

4.1. Monero Overview

This section covers the core technology and philosophy behind the Monero cryptocurrency.

4.1.1. Origins and Philosophy

Monero evolved from the CryptoNote protocol proposed in 2013, which aimed to solve what its author called a "critical flaw" in Bitcoin—traceability [28]. It was initially launched under the name Bitmonero by a developer known as "thankful_for_today," and was soon forked by the community into Monero, meaning "coin" in Esperanto [28].

From the outset, Monero's design centered around privacy and fungibility. It aimed to function as digital cash with indistinguishable units—just like physical currency [24].

4.1.2. Core Privacy Technologies

Monero's privacy-focused design is built on three foundational technologies [25], [28]:

- **Ring Signatures:** When a user sends Monero, the transaction is grouped with decoy outputs of similar amounts. Observers cannot determine which output is being spent, obscuring the real signer [28].
- **Ring Confidential Transactions (RingCT):** RingCT conceals the amount being transferred, replacing visible numbers with cryptographic proof that the input equals the output [28].
- **Stealth Addresses:** Instead of using the recipient's public key directly, Monero generates a unique one-time address for each transaction. Only the actual owner can retrieve the funds, while outsiders see only a random identifier [28].
- **Dandelion++:** An optional network-level feature that helps mask the user's IP address by bouncing the transaction between nodes before it is broadcast [25].

Together, these technologies ensure that Monero transactions are unlinkable, untraceable, and confidential by default. This level of privacy is deeply embedded in the protocol and is continually improved by its open-source community [25].

4.2. Monero in the Real World

This section describes some of the nefarious uses of Monero, including network abuse.

4.2.1. Illicit Use Cases

Monero's robust privacy has attracted increasing adoption within underground markets. Cybercriminals and darknet vendors are migrating from Bitcoin to Monero, particularly after law enforcement successfully traced and recovered Bitcoin in high-profile ransomware cases such as the Colonial Pipeline attack [27].

Groups like REvil and DarkSide now demand ransom payments in Monero, sometimes offering discounts as incentives [24], [27]. The darknet marketplace AlphaBay was among the first major platforms to accept Monero as an alternative to Bitcoin, citing its improved privacy protections [28].

4.2.2. Cryptojacking and Mining Abuse

Monero's ease of mining using CPUs has also made it the currency of choice for cryptojacking. Hackers have injected Monero mining scripts into websites, streaming platforms, and even public Wi-Fi networks (e.g., Starbucks in Argentina) to mine the currency covertly [29].

In one case, Russia's state-owned pipeline company Transneft discovered that hackers were mining Monero using corporate infrastructure, raising concerns over productivity loss and data integrity [29].

4.3. Attempts to Break Monero's Anonymity

Despite its advanced privacy features, Monero has become the subject of increasing scrutiny by regulators and blockchain analysis firms.

4.3.1. Government Bounties and Research

In 2020, the U.S. Internal Revenue Service (IRS) issued a public bounty offering $625,000 for solutions to trace Monero transactions [26]. Contracts were eventually awarded to Chainalysis and Integra FEC, which specialize in blockchain forensics [24], [26].

4.3.2. Chain Analytics and Statistical Attacks

Though Monero obscures transaction details, its ledger is still public. Researchers have explored techniques such as *temporal analysis*—correlating transaction times—and *ring size forensics*, which target older transactions created when the protocol allowed fewer decoys [28].

These approaches rely heavily on probabilistic models. For example, if users consistently use low-entropy decoy sets or repeat timing patterns, their transactions may become de-anonymizable under certain statistical frameworks [26].

4.3.3. Forensics Companies and Analytics

Blockchain intelligence firms like CipherTrace and Chainalysis have claimed partial breakthroughs in tracing Monero transactions, though these methods have not been publicly validated. Analysts agree that Monero's cryptography makes address clustering—so effective in Bitcoin—far less reliable [24].

4.3.4. User and Platform Mistakes

Even perfect cryptography can be undone by user error. If a Monero user reuses an address, shares a transaction ID publicly, or converts funds via a centralized exchange, they risk linking their identity to otherwise anonymous transactions [27].

Centralized exchanges that comply with Know-Your-Customer (KYC) regulations can retain identifying information that may later be subpoenaed or leaked.

4.3.5. Network-Level Surveillance

Monero obfuscates blockchain data, but transactions are still sent over the internet. Without routing through Tor, I2P, or VPNs, attackers with sufficient network visibility may correlate IP addresses and timestamps with blockchain activity [26]. Similar to known attacks on the Tor network, surveillance at the entry and exit nodes may reveal more than the user intended.

4.4. Real-World Constraints and Regulatory Impact

Despite its strong privacy protections, Monero faces real-world limitations:

- **Liquidity Barriers:** Many regulated exchanges refuse to list Monero due to concerns over Anti-Money Laundering (AML) compliance [27].
- **Insurance Restrictions**: Cyber insurers often refuse to reimburse ransoms paid in Monero, making it less practical in ransomware incidents [27].
- **Regulatory Pressure:** Governments have focused on regulating Monero's on- and off-ramps rather than banning the currency directly. This includes pressuring exchanges to delist Monero and blocking fiat-to-Monero conversions [27].

These restrictions can make it difficult for malicious actors to acquire or liquidate Monero during time-sensitive operations [24], [27].

4.5. Monero Conclusion

Monero represents the cutting edge of privacy in cryptocurrency. With its suite of cryptographic protections—RingCT, stealth addresses, and ring signatures—Monero offers anonymity far beyond what Bitcoin or Ethereum can achieve. Yet it is not invincible. Law enforcement agencies and cybersecurity firms continue to probe for weaknesses through statistical analysis, network surveillance, and user error.

Its future will depend not only on its cryptographic resilience but also on how users maintain operational security and how regulators restrict access in the future. Regardless of the outcome, Monero remains at the heart of the global debate over privacy, surveillance, and digital finance [25].

5. Non-Cryptographic Security Concerns With Cryptocurrencies

A system is only as secure as its weakest link. A bank vault's walls can be reinforced with literally indestructible materials, but if the keycard required to open the vault door is left lying around unattended, those walls don't matter much. Likewise, despite the many security benefits the blockchain has against attacks on itself through its underlying secure cryptography scheme, it doesn't matter much if the systems surrounding it are insecure. In cryptocurrency specifically, this leads to two major concerns, covered in the following sections.

5.1. Pseudonymity is not Anonymity

Bitcoin and the multitude of cryptocurrencies based on it are not truly anonymous—instead, they are pseudonymous. While personally identifying information is not shown, all wallet addresses, their transactions, and asset holdings are all open to the public. This leaks critical information that can then be used to personally identify the owner or easily trace funds in multiple ways [31], [32]:

- **Association Analysis:** Since all transaction data is publicly available, it is trivial to find groups of wallets that are "associated" with one another by simply examining how often they send funds to each other [31].
- **Cross-Referencing Known Personal Information:** Transaction history can be used alongside publicly available information to link a wallet to a person. For example, say the CEO of a cryptocurrency company takes their salary in Bitcoin. An adversary would simply need to find wallets with transactions that match their pay package [31], [32].
- **"Know Your Customer" (KYC) Rules:** Most major centralized exchanges (where most cryptocurrency exchanges occur) require users to link their real-world identities to their wallets to use their services, a process called "Know Your Customer," or KYC. Exchanges implement KYC to combat money laundering; however, it hurts the blockchain's pseudonymity. Any security faults in the centralized exchange would cause the wallet-identity links to suddenly be made known [31].

It *is* possible to mitigate these issues with pseudonymity. However, it requires a large amount of effort on the part of the end-user in terms of operational security, and it is relatively easy to accidentally leak information that can then be used to correlate a user's real-world identity with their wallet and track their funds [31], [32].

5.2. No "Undo" Button

Due to cryptocurrency's decentralized nature, there is no way to "undo" a single transaction without forking the entire blockchain, which essentially means creating an entirely new cryptocurrency.

Even if it were possible to convince everyone using the old fork to migrate to the new one (not easy to do), the forking process would be required every single time a transaction was to be undone, making it entirely impossible to do in any sort of large scale system (at least, if you aren't a user with incredibly high amounts of leverage to convince the coin creators to fork the chain to undo a transaction for you). Consequently, there is zero recourse for an attack on the systems surrounding the blockchain or for any scams that may occur [32]. Because of this, users can oftentimes be at the mercy of the operational security of the systems surrounding their specific blockchain, such as their account integrity on major exchanges.

6. Save the Kids Cryptocurrency: A Case Study

The "Save the Kids" token (not to be confused with the Save the Children charity organization) is a good case study for demonstrating the non-cryptographic security concerns of many "typical" cryptocurrencies.

6.1. Save the Kids Overview

Released in 2021, Save the Kids was a token whose promoters claimed it would be a long-term project seeking to become regularly traded while also taking some of the transaction fees and donating them to charity [33]. Users could buy into the project by trading their Binance Coin (BNB) for the token on the Pancakeswap exchange.

Upon launch, however, large holders of the token (who had bought them in the presale) dumped their holdings onto the market as people bought in off the hype generated by the promoters, a lot of whom were simultaneously large holders themselves. The price immediately collapsed 75% within 24 hours of launch and continued to drop to a valuation of $0 [34].

6.2. Subsequent Investigation

The subsequent investigation was set on answering one question: was this project simply an instance of a team earnestly trying and failing to deliver on their promises, or was the entire project a honeypot? To answer this, YouTube creator and cryptocurrency journalist Stephen Findeisen (known online by his alias "Coffeezilla") used the lack of true anonymity in most cryptocurrencies to look deeper into the transaction histories of public figures that promoted it. He used previous public statements and crypto giveaways from the promoters to find root wallets for each of them.

From there, he looked into the transaction history of the root wallets to find wallets that they frequently traded with in a manner that suggested the same person owned them to create a list of wallets for each person.

Finally, he looked for transactions in each group of wallets to find who bought into Save the Kids during the presale. Once he had the wallets for each person and the associated funds in Save the Kids tokens, he could see exactly what each promoter did with their tokens. After all, anyone sincerely invested in the project would hold onto those tokens for some time, rather than selling the moment they could to the public.

He found a mix of sincere investment from a few promoters, but most took the tokens they bought in presale and immediately sold them the moment they were available for the public to buy. With this evidence, it was pretty clear that what had occurred was a pump-and-dump scam [30], [34].

In essence, Findeisen cross-referenced known information and used wallet association analysis to break the pseudonymity of the Save the Kids cryptocurrency and expose the underlying scam.

6.3. Why the Scam Worked So Well

Now, in a normal financial exchange, there would be *some* level of recourse for fraud committed. Credit card companies and banks can issue chargebacks, stock exchanges can undo transactions signed by mistake, etc [35], [36], [37]. Even barring any action from the financial institutions, one can simply take the perpetrator to court.

However, none of those safeguards exist in crypto. As discussed before, there is no “undo” button for transactions in crypto, even if they are predicated on fraud [32]. There isn’t even much of a means to sue or press charges, since cryptocurrency trading in the US is largely unregulated [38]. Even though the people behind Save the Kids (creators, developers, promoters, etc) were based in the US, there was no means for the victims to get their money back.

The only recourse was the reputational damage done to the promoters and the termination of their employment [33].

Even with sound mathematical proofs, this case study reminds us that the greatest vulnerabilities of our time often lie not in code—but in people.

[Final Project Video]
[Final Project Video Slides]

References

[1] "History of Blockchain," GeeksforGeeks, Mar. 10, 2021. https://www.geeksforgeeks.org/history-of-blockchain/

[2] S. Nevil, "What Is Proof of Work (PoW) in Blockchain?," Investopedia, May 17, 2024. https://www.investopedia.com/terms/p/proof-work.asp

[3] S. Nakamoto, "Bitcoin: a Peer-to-Peer Electronic Cash System," bitcoin.org, 2008. Available: https://bitcoin.org/bitcoin.pdf

[4] Wikipedia Contributors, "Cryptocurrency," Wikipedia, Feb. 15, 2019. https://en.wikipedia.org/wiki/Cryptocurrency

[5] Wikipedia, "Blockchain," Wikipedia, Mar. 14, 2019. https://en.wikipedia.org/wiki/Blockchain

[6] A. Loo, "Hash Function," Corporate Finance Institute, 2022. https://corporatefinanceinstitute.com/resources/cryptocurrency/hash-function/

[7] L. Wagner, "How SHA-256 Works Step-By-Step," blog.boot.dev, Jul. 08, 2020. https://blog.boot.dev/cryptography/how-sha-2-works-step-by-step-sha-256/

[8] Monero Community, "Keccak-256 Hash Function - Monero Docs," Getmonero.org, 2015. https://docs.getmonero.org/cryptography/keccak-256/ (accessed Apr. 19, 2025).

[9] Wikipedia Contributors, "Elliptic-curve cryptography," Wikipedia, Nov. 18, 2019. https://en.wikipedia.org/wiki/Elliptic-curve_cryptography

[10] S. River, "Secp256k1 | River Glossary," River, 2025. https://river.com/learn/terms/s/secp256k1/ (accessed Apr. 19, 2025).

[11] P. Sutra Dhor, "The Mathematics behind Blockchain." Available: https://blockchain.ieee.org/images/files/pdf/techbriefs-2022-q3/the-mathematics-behind-blockchain.pdf

[12] Enigbe Ochekliye, "Elliptic Curves and the Discrete Log Problem," Medium, May 23, 2022. https://enigbe.medium.com/about-elliptic-curves-and-dlp-ed76c5e27497

[13] "When adding two points on an elliptic curve, why flip over the x-axis?," Cryptography Stack Exchange, Dec. 15, 2017. https://crypto.stackexchange.com/questions/53974/when-adding-two-points-on-an-elliptic-curve-why-flip-over-the-x-axis (accessed Apr. 19, 2025).

[14] "Merkle Tree," Investopedia, 2019. https://www.investopedia.com/terms/m/merkle-tree.asp

[15] "7. The Blockchain - Mastering Bitcoin [Book]," www.oreilly.com. https://www.oreilly.com/library/view/mastering-bitcoin/9781491902639/ch07.html

[16] "Blockchain.com Explorer | BCH | ETH | BCH," www.blockchain.com. https://www.blockchain.com/explorer/blocks/btc/000000000019d6689c085ae165831e934ff763ae46a2a6c172b3f1b60a8ce26f

[17] sCrypt, "Proof of Work in Bitcoin - sCrypt - Medium," Medium, Feb. 28, 2024. https://scryptplatform.medium.com/proof-of-work-in-bitcoin-043ff9fa0d2d (accessed Apr. 19, 2025).

[18] "How Many Bitcoin Are There? How Much Supply Left to Mine?," Bitbo.io, 2016. https://bitbo.io/how-many-bitcoin (accessed Apr. 19, 2025).

[19] Bitcoin Developer Guide, "Transactions," *developer.bitcoin.org*, https://developer.bitcoin.org/devguide/transactions.html (accessed Apr. 22, 2025).

[20] Bitcoin Wiki, "Script," *en.bitcoin.it*, https://en.bitcoin.it/wiki/Script (accessed Apr. 22, 2025).

[21] S. Noether, A. Mackenzie, and the Monero Core Team, "Ring Confidential Transactions," *Ledger*, vol. 1, pp. 1-18, 2016. PDF: https://ledgerjournal.org/ojs/index.php/ledger/article/view/34/29 (accessed Apr. 22, 2025).

[22] B. Bünz, J. Bootle, D. Boneh, A. Poelstra, P. Wuille, and G. Maxwell, "Bulletproofs: Short Proofs for Confidential Transactions and More," Proc. IEEE S&P 2018. Pre-print: https://eprint.iacr.org/2017/1066.pdf (accessed Apr. 22, 2025).

[23] Monero Research Lab, *Zero to Monero: A Technical Guide to a Private Digital Currency*, v1.0, 2018. https://www.getmonero.org/library/Zero-to-Monero-1-0-0.pdf (accessed Apr. 22, 2025).

[24] H. Murphy, "Monero emerges as crypto of choice for Cybercriminals," Monero emerges as crypto of choice for cybercriminals, https://www.ft.com/content/13fb66ed-b4e2-4f5f-926a-7d34dc40d8b6 (accessed Apr. 17, 2025).

[25] Monero-Project, "Monero-project/Monero: Monero: The Secure, private, untraceable cryptocurrency," GitHub | Monero, https://github.com/monero-project/monero (accessed Apr. 17, 2025).

[26] L. Franceschi-Bicchierai, “The IRS wants to buy tools to trace privacy-focused cryptocurrency Monero,” VICE, https://www.vice.com/en/article/the-irs-wants-to-buy-tools-to-trace-privacy-focused-cryptocurrency-monero/ (accessed Apr. 17, 2025).

[27] M. Sigalos, “Why some cyber criminals are ditching bitcoin for a cryptocurrency called Monero,” CNBC, https://www.cnbc.com/2021/06/13/what-is-monero-new-cryptocurrency-of-choice-for-cyber-criminals.html (accessed Apr. 17, 2025).

[28] A. Greenberg, “Monero, the drug dealer’s cryptocurrency of choice, is on fire,” Wired, https://www.wired.com/2017/01/monero-drug-dealers-cryptocurrency-choice-fire/ (accessed Apr. 17, 2025).

[29] S. Melendez, “Highly anonymized cryptocurrency Monero peeks out of the Shadows,” FastCompany, https://www.fastcompany.com/40505925/highly-anonymous-cryptocurrency-monero-peeks-out-of-the-shadows (accessed Apr. 17, 2025).

[30] S. Findeisen, “Save The Kids - The Final Chapter,” *Coffeezilla*. Jul 27, 2021. Accessed: Mar. 25, 2025. [Online]. Available: https://www.youtube.com/watch?v=3Xw9rWmTQfc&ab_channel=Coffeezilla

[31] A. Buczak, “Is Bitcoin Anonymous? The Myth of Anonymity Debunked,” Ulam Labs. Dec 30, 2024. https://www.ulam.io/blog/is-cryptocurrency-anonymous (accessed Apr. 17, 2025).

[32] D. Olson, “Line Goes Up – The Problem With NFTs,” *Folding Ideas*. Jan. 21, 2022. Accessed: Mar. 25, 2025. [Online]. Available: https://www.youtube.com/watch?v=YQ_xWvX1n9g&ab_channel=FoldingIdeas

[33] J. Fingas, “FaZe Clan suspends players allegedly involved in crypto pump-and-dump scheme,” Engadget. Jul 3, 2021. https://www.engadget.com/faze-clan-suspends-crypto-scheme-players-221223343.html (accessed Apr. 17, 2025).

[34] Protos Staff, “Esports influencer fired for pumping and dumping ‘Save The Kids’ crypto,” Protos. Jul 15, 2021. https://protos.com/save-the-kids-faze-clan-kay-coffeezilla-proves-rug-pulls/ (accessed Apr. 17, 2025).

[35] N. Campisi, D. Nici, “Scammed Out Of Money On Zelle? You Might Be Able To Get It Back,” Forbes. Nov 14, 2023.

https://www.forbes.com/advisor/money-transfer/zelle-users-refunded-after-scams/ (accessed Apr. 17, 2025).

[36] "What To Do if You Were Scammed," United States Federal Trade Commission. Jul 2022. https://consumer.ftc.gov/articles/what-do-if-you-were-scammed (accessed Apr. 17, 2025).

[37] A. Osipovich, K. Langley, "NYSE to Unwind Trades in Berkshire Hathaway After Glitch Causes Crash of Over 99%," Wall Street Journal. Jun 3, 2024. https://www.wsj.com/livecoverage/stock-market-today-dow-sp-500-nasdaq-live-06-03-2024/card/data-glitch-causes-apparent-crash-of-over-99-in-berkshire-hathaway-other-stocks-VFnqjRItcN4ISXwxem0a (accessed Apr. 17, 2025).

[38] "Always Use Caution When Investing in Cryptocurrency," Tennessee Department of Commerce and Insurance. Jan 20, 2023. https://www.tn.gov/commerce/blog/2023/1/30/always-use-caution-when-investing-in-cryptocurrency.html (accessed Apr. 17, 2025).